

ICS 33.030

CCS M 21

团体标准

T/TAF 209.5—2024

移动互联网应用程序（APP）合规开发管理 测评规范 第5部分：对外接口管理

Evaluation specification for compliance development of mobile Internet
application—Part 5: External interface management

2024-02-23 发布

2024-02-23 实施

电信终端产业协会 发布

目 次

前言 II

引言 III

1 范围 1

2 规范性引用文件 1

3 术语和定义 1

4 概述 1

5 对外接口需求设计阶段管理要求 2

6 对外接口功能实现阶段管理要求 2

7 对外接口运行维护阶段管理要求 3

8 对外接口管理测试方法 4

附录 A（资料性）数据开放平台对外接口管理实践示例 5

前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

本文件是T/TAF 209《移动互联网应用程序（APP）合规开发管理测评规范》的第5部分。T/TAF 209已经发布了以下部分：

- 第1部分：总则；
- 第2部分：需求设计；
- 第3部分：功能测试；
- 第4部分：代码审计；
- 第5部分：对外接口管理；
- 第6部分：应用编程接口（API）管理；
- 第7部分：更新升级管理；
- 第8部分：数据使用管理；
- 第9部分：算法模型；
- 第10部分：人员能力；
- 第11部分：能力成熟度评估。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由电信终端产业协会提出并归口。

本文件起草单位：中国信息通信研究院、华为技术有限公司、华为终端有限公司、维沃移动通信有限公司、北京微梦创科网络技术有限公司、荣耀终端有限公司。

本文件主要起草人：王艳红、武林娜、王淞鹤、周飞、李京典、陈鑫爱、李可心、李实、衣强、刘金坡、程责果、赵盈洁、任资政、邹庆、赵晓娜、李辰淑。

引 言

随着互联网技术和服务的迅速发展，APP提供的服务范围已几乎覆盖工作生活的各个领域，与此同时也涉及了大量个人信息的使用及流转。随着国家《个人信息保护法》、《数据安全法》等相关法规的出台，各种APP个人信息保护的政策和监察行动也相继开展。为确保APP在为用户提供服务的同时能更好的保护用户个人信息的安全性，APP开发者除需要满足法律法规和监管要求外，更应将个人信息保护要求融入APP设计开发环节，从源头对APP的个人信息处理活动提供保障。

其中，针对个人信息共享场景，由于涉及到个人信息在多个个人信息处理者之间的流转，个人信息保护问题更加需要得到重视。而对外接口作为个人信息在不同个人信息处理者之间流转的传输通道，在设计开发阶段，需要着重考虑个人信息保护要求。

本文件针对个人信息共享场景下，APP开发运营者在设计、开发、使用个人信息对外接口过程中需要考虑的合规管理内容，从需求设计、功能实现、运行维护各阶段提出相应的对外接口管理要求，为APP开发者规范对外接口的设计、开发和使用提供指导。

T/TAF 209旨在对APP开发流程、功能模块、工程管理等提出合规开发管理要求，拟由11部分构成。

- 第1部分：总则。目的在于给出规范移动互联网应用程序（APP）合规开发的总体原则和要求。
- 第2部分：需求设计。目的在于提出规范APP需求设计环节的相关合规开发要求。
- 第3部分：功能测试。目的在于规范移动互联网应用程序（APP）在合规开发阶段满足功能测试的标准要求。
- 第4部分：代码审计。目的在于规范APP代码审计过程，提升代码安全管理能力。
- 第5部分：对外接口管理。目的在于规范APP对外接口的合规开发和使用管理，提升合规能力。
- 第6部分：应用编程接口（API）管理。目的在于规范APP在开发过程中对于API的使用，提升合规能力。
- 第7部分：更新升级管理。目的在于规范APP合规开发在更新升级阶段的要求，提升APP更新升级管理能力。
- 第8部分：数据使用管理。目的在于规范APP在合规开发过程中数据使用的合规管理，提升数据使用合规管理能力。
- 第9部分：算法模型。目的在于规范APP合规开发在算法模型方面的要求，提升APP算法模型开发的合规管理能力。
- 第10部分：人员能力。目的在于规范APP在合规开发过程中的人员能力管理。
- 第11部分：能力成熟度评估。目的在于规范APP在合规开发管理过程中的能力成熟度评估。

移动互联网应用程序（APP）合规开发管理测评规范 第5部分：对外接口管理

1 范围

本文件规定了在个人信息共享场景下，APP开发运营者在设计、开发、使用个人信息对外接口过程中需要考虑的合规管理内容，并从需求设计、功能实现、运行维护各阶段提出相应的对外接口管理要求。

本文件适用于指导APP开发运营者设计、开发、使用个人信息对外接口。也适用于监管机构、第三方评估机构对APP开发运营者开发的个人信息对外接口的合规性进行监督、评估与认证。

2 规范性引用文件

本文件没有规范性引用文件。

3 术语和定义

下列术语和定义适用于本文件。

3.1

移动互联网应用程序 **mobile Internet application**

可安装在移动智能终端内，能够利用移动智能终端操作系统提供的公开开发接口，实现某项或某几项特定任务的应用程序。

3.2

对外接口 **external interface**

不同个人信息处理者之间，进行个人信息共享的边界。

3.3

APP开发运营者 **application developer and operator**

从事APP开发和运营活动的主体。

3.4

个人信息共享 **sharing**

个人信息处理者向其他处理者提供个人信息，且双方分别对个人信息拥有独立控制权的行为。

4 概述

本文件中的对外接口是指所有涉及个人信息共享场景下,在个人信息提供方与个人信息接收方之间的个人信息传输通道,如图1所示。个人信息接收方通过对外接口申请获取个人信息,个人信息提供方验证接收方身份及接口传入参数等信息,并通过接口对外提供个人信息。

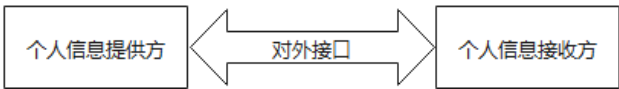


图 1 对外接口示意图

对外接口的开发和使用应遵循以下原则:

- 一致性原则: 个人信息提供方和个人信息接收方应遵从相同的规则开发、使用对外接口;
- 稳定性原则: 对外接口应具有一定的稳定性, 避免任意一方随意改动;
- 安全性原则: 应采用必要的管理和技术措施保障对外接口访问及个人信息共享的安全性;

5 对外接口需求设计阶段管理要求

APP开发运营者在对外接口需求设计阶段的管理要求如下:

- a) 应结合业务功能, 明确对外接口的共享个人信息范围;
- b) 应对对外接口的个人信息共享内容、接收方、处理目的及方式等进行个人信息保护影响评估, 确保通过对外接口的个人信息共享符合国家相关法律法规要求;
- c) 对外接口应遵循统一的规则, 包括: 接口名称、数据格式、参数、返回码、错误码等;
- d) 对外接口应提供完整、详细的使用说明文档, 文档内容包括: 接口功能说明、参数说明、返回结果说明、错误码说明等, 以帮助接口调用者理解并正确使用接口;
- e) 个人信息共享双方应通过签订合同等方式制定个人信息共享规则, 以便约束双方的个人信息共享行为, 确保个人信息共享的安全性, 内容可包括: 个人信息共享范围、共享双方责任义务等。

6 对外接口功能实现阶段管理要求

6.1 个人信息提供方对外接口管理要求

6.1.1 访问控制要求

针对个人信息提供方的访问控制要求如下:

- a) 应设置合理的接口访问权限, 如: 接口公开级别、用户身份等级等, 以确保接口仅可被授权应用访问;
- b) 宜对共享个人信息进行分类分级, 并对不同类别或不同等级的个人信息设置不同的访问权限;
- c) 应建立、维护接口访问应用的权限列表, 定期进行安全检测, 并在必要时进行更新;
- d) 个人信息共享前, 应验证个人信息接收方的身份及访问权限, 避免未授权的个人信息共享。

6.1.2 数据传输要求

针对个人信息提供方的数据传输要求如下:

- a) 应对接口请求及传入参数进行有效性验证，对检测到的异常请求实施有效拦截，如：非授权的数据传输请求、超范围频繁调用、请求数据不存在、参数类型/格式错误、恶意请求等，防止接口被滥用或恶意攻击；
- b) 应对接口请求的异常情况设置适当的错误码返回信息，以便接口调用者能够及时了解异常情况，并对异常情况进行处理和响应；
- c) 宜对接口设置异常情况的容错机制，如接口调用失败的重试机制等；
- d) 宜根据业务实际情况，必要时在个人信息传输前对其进行脱敏处理；
- e) 以同意为合法性基础的，应在共享个人信息前明确是否已向用户进行告知并获得用户单独同意。如未获得用户单独同意，应拒绝进行个人信息传输；
- f) 应确保共享的个人信息满足业务功能所需的最小范围；
- g) 应采用安全传输方式确保个人信息传输的安全性。

6.2 个人信息接收方对外接口管理要求

6.2.1 接口访问要求

针对个人信息接收方的接口访问要求如下：

- a) 应按照接口使用说明文档要求对接口进行访问；
- b) 当涉及多个对外接口访问时，应在授权范围内，以满足业务功能所需的最小范围对接口进行访问；
- c) 应以满足业务功能所需的最小频率对接口进行访问请求，不应过度、频繁访问接口；
- d) 不应滥用或对接口进行恶意攻击，如：SQL注入攻击、跨站点脚本攻击等；
- e) 应以满足业务功能所需的最小范围申请个人信息，不应超范围申请不必要的个人信息；
- f) 不应擅自将接口访问权限转让给其他个人信息接收方。

6.2.2 个人信息接收及处理要求

个人信息接收方应按约定的个人信息处理目的、方式、范围处理接收的个人信息。

7 对外接口运行维护阶段管理要求

7.1 升级要求

对外接口应满足以下升级及版本管理要求：

- a) 接口应可升级，包括接口扩展、接口弃用等，并对接口的不同版本进行维护管理；
- b) 接口升级后，新版本接口不应对其他接口或与此接口无关的其他功能产生影响；
- c) 接口升级后，如共享个人信息范围或接口访问权限发生变化，应重新评估接口访问应用权限列表，并进行及时更新；
- d) 接口升级后，应同步更新接口使用说明文档的相关内容。

7.2 日志记录要求

对外接口调用方或接口提供方应满足以下日志记录要求：

- a) 应对接口的调用情况提供日志记录，包括调用时间、操作内容、返回结果状态码等，以便监控和追踪接口的使用情况和性能；
- b) 应对日志记录进行存储，并设置合理的存储期限，以便用于追溯和审计；
- c) 应在必要时对存储的日志记录进行审计。

8 对外接口管理测试方法

APP对外接口合规开发管理的测试方法主要采用资料审查、技术验证和人员访谈对各项要求进行符合性评估。管理要求与测评方式对应关系如表1所示。

表 1 管理规范与测评方式对应关系表

要求条款	测评方式		
	资料审查	技术验证	人员访谈
5.1 a)	√	—	√
5.1 b)	√	—	—
5.1 c)	√	—	—
5.1 d)	√	—	—
5.1 e)	√	—	√
6.1.1 a)	√	√	—
6.1.1 b)	√	√	—
6.1.1 c)	√	—	√
6.1.1 d)	√	√	—
6.1.2 a)	√	√	—
6.1.2 b)	√	√	—
6.1.2 c)	√	√	—
6.1.2 d)	√	√	—
6.1.2 e)	√	√	—
6.1.2 f)	√	√	—
6.1.2 g)	√	√	—
6.2.1 a)	√	√	—
6.2.1 b)	√	√	—
6.2.1 c)	√	√	—
6.2.1 d)	√	√	—
6.2.1 e)	√	√	—
6.2.1 f)	—	√	√
6.2.2	√	√	—
7.1 a)	√	√	—
7.1 b)	—	√	—
7.1 c)	√	—	√
7.1 d)	√	—	√
7.2 a)	√	√	—
7.2 b)	√	√	—
7.2 c)	√	—	√
注：“√”表示可采用的测评方式；“—”表示不适用。			

附 录 A
(资料性)
数据开放平台对外接口管理实践示例

在数据处理者进行个人信息共享场景中，以数据处理者构建的数据开放平台为示例，说明平台对外接口的能力及合规实践。开放平台接口相关能力概况见图A. 1所示。在个人信息共享的各个阶段，数据提供方和数据接收方通过平台对外共享接口，按照事前声明、事中监控、事后审计的原则，实现个人信息的安全共享。



图 A. 1 开放平台接口相关能力概况

数据开放平台将个人信息合法合规要求转化为平台运行机制和规则，部署到平台数据流转的各个环节，如：根据数据的类型、数量、安全级别，设置不同的访问控制策略，并采取适当措施确保数据持续处于有效保护和合法利用的状态。在数据输入和输出平台时，应充分保护数据的安全性，具体措施如下：

- 在数据输入平台时，禁止不合规的数据进入平台，如未经过用户授权的个人敏感数据；
- 在数据输出平台时，应严控输出场景与审批，防止数据泄露。

当数据提供方通过对外接口将数据接入平台时，通过梳理数据接入场景与要求，规范接入方案，打造稳定、高效、安全的数据接入服务，包括：

- 支持对源数据的设计、接入、审核能力，离线/实时数据的接入管理能力；
- 提供多样化的数据推送/采集能力；
- 实时监控数据接入任务状态，及时告警并进行干预。

当数据接收方通过对外接口从平台共享数据时，需要遵从整体数据分类分级对数据安全和隐私的管理要求，在合规的前提下实现数据高效共享。



电信终端产业协会团体标准

移动互联网应用程序（APP）合规开发管理测评规范
第 5 部分：对外接口管理

T/TAF 209.5—2024

*

版权所有 侵权必究

电信终端产业协会印发
地址：北京市西城区新街口外大街 28 号
电话：010-82052809
电子版发行网址：www.taf.org.cn